



skillsoft
global knowledge



END-TO-END VULNERABILITY MANAGEMENT SYSTEM

Enterprise Lab Deployment & Risk Mitigation

Digital Egypt Pioneers Initiative (DEPI)

Track: Information Security Analyst

July 2026

Team Members



Ahmed Mohamed Gharib

CVSS scoring, risk mapping, exception documentation (EXP-2026-001, Windows EOL).



Amer Ehab Amer

Executes all patching commands (apt upgrade, GPO, PowerShell), verifies fixes.



Khaled Elsayed Salem

Owns the final Word report, slide consistency, and DEPI submission package.



Kareem Ahmed Rashad

Sets up Windows/Ubuntu targets, installs vulnerable apps, opens ports for scanning.



Mahmoud Hamdy Mobarak

Builds the Executive Dashboard, KPI/SLO charts and final presentation slides.



Muhammed Mustafa Gomaa

Designs all 6 scan phases, configures Nessus Essentials, owns the full scan lifecycle.

Project Objectives

Establish a Full Lifecycle

Implement a complete Vulnerability Management workflow based on industry standards (NIST SP 800-40).

Proactive Security

Transition from a reactive "firefighting" mindset to a structured, continuous risk assessment.

Business Alignment

Convert technical scanner data into actionable executive metrics, KPIs, and SLOs.

Practical Defense

Apply real-world remediation, patch management, and compensating controls.



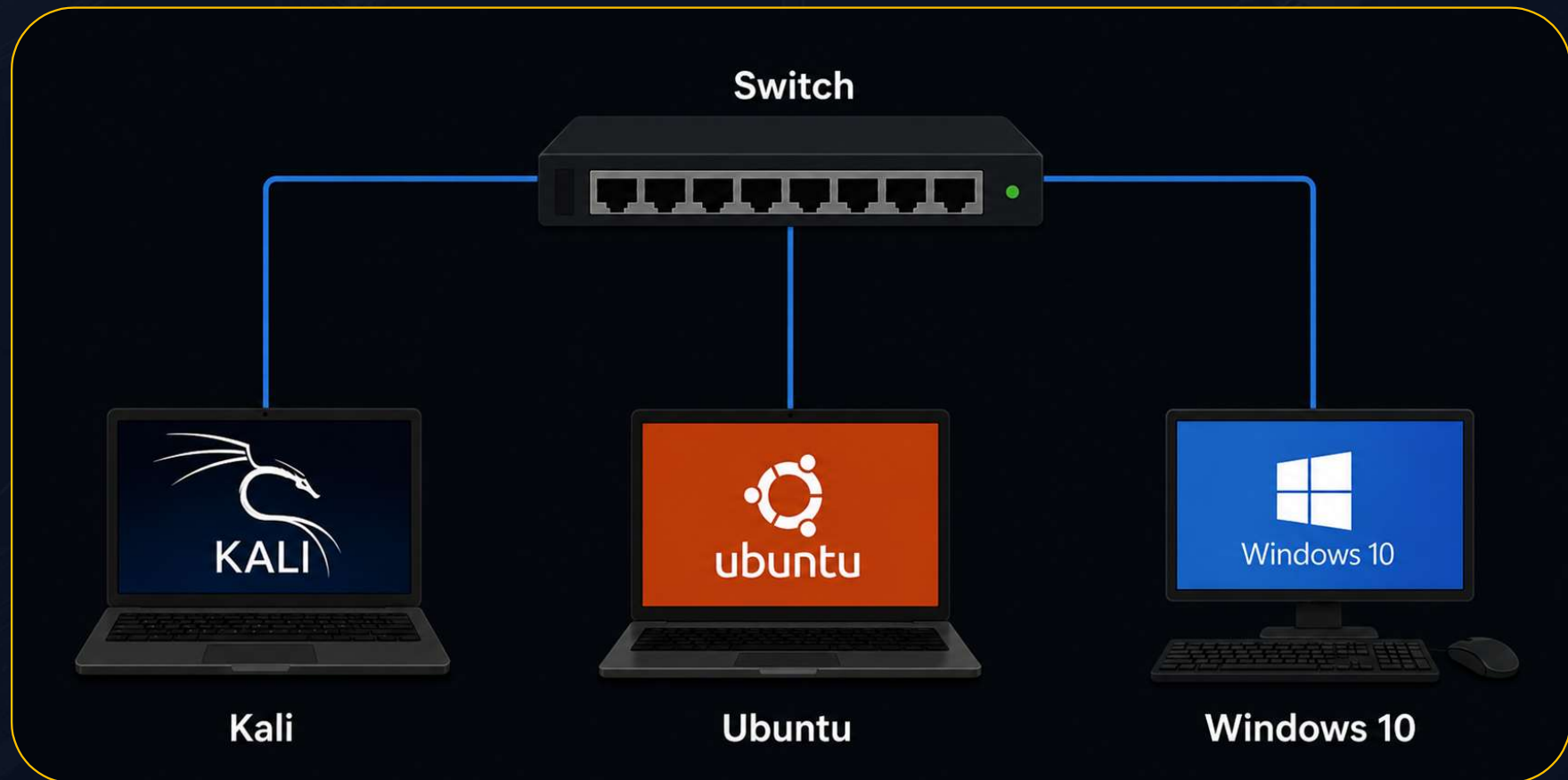
Lab Architecture & Topology

Isolated Testing Environment

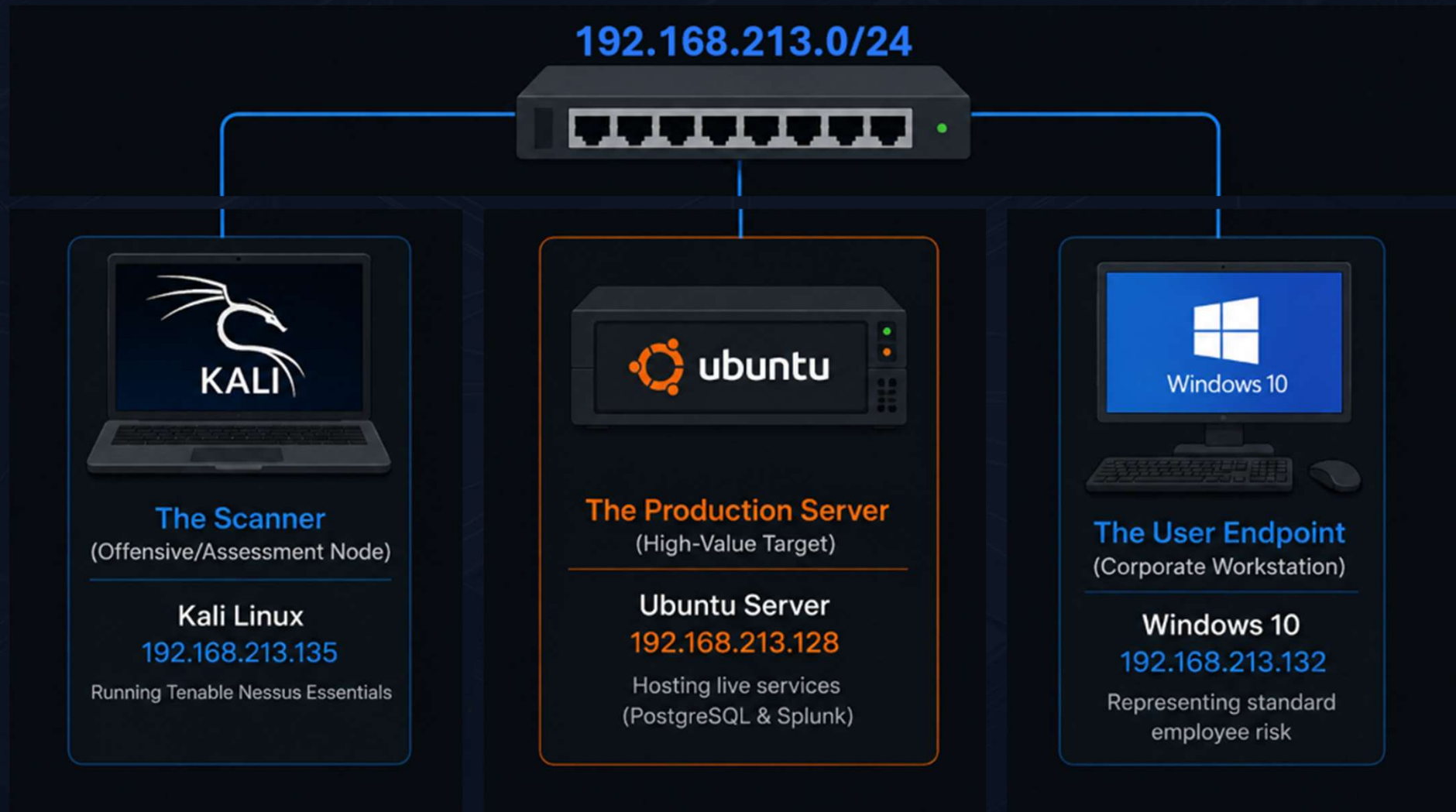
Built entirely on a virtualized environment using a strict host-only/NAT network layout.

Network Range

Subnet dedicated to the lab is **192.168.213.0/24**.



Target Asset Roles & Breakdown



6-Phase Vulnerability Scanning Lifecycle

Each phase builds on the previous — from passive discovery to full credentialed deep inspection.

01 Asset Discovery



Type: Host Discovery
Target: 192.168.213.0/24

3 hosts mapped

02 Non-Credentialed Scan



Type: Basic Network
Target: Both IPs

30 vulns (Low/Med)

03 Windows Credentialed



Type: Basic Network + Creds
Target: 192.168.213.132

55 vulns (HIGH/MIXED)

04 Ubuntu Credentialed



Type: Basic Network + SSH
Target: 192.168.213.128

58 vulns (HIGH/MIXED)

05 Windows Audit (Post-Fix)



Type: Basic Network + Creds
Target: 192.168.213.132

11 remaining (EOL OS)

06 Ubuntu Verification



Type: Basic Network + SSH
Target: 192.168.213.128

0 High/Critical ✓

Asset Discovery



Asset Discovery & Scoping

The Rule of VM

You cannot protect what you do not know exists.

Techniques Used

Combined ICMP Echo requests, ARP pinging, and initial TCP port discovery to map active daemons.

The Scan Type

Executed a "Host Discovery Scan" across the entire network block (**192.168.213.0/24**).

Lab Asset Discovery

[Back to My Scans](#)

Hosts 6 Vulnerabilities 2 History 1

Filter Search Hosts 6 Hosts (3 Selected)

Host	Ports
☐ 192.168.213.254	
☒ 192.168.213.135	
☒ 192.168.213.132	135, 139, 445, 49664, 49665, 49666, 49667, 49668, 49669, 49671
☒ 192.168.213.128	
☐ 192.168.213.2	

Scanning Methods



Scanning Methods



Unauthenticated Scanning (Outside-In View)

- The scanner probes the targets over the network with *no login privileges*.
- Mimics an external or rogue attacker on the network.
- Discovers exposed perimeter services, missing encryption, and open ports.



Credentialed Scanning (Inside-Out View)

- The scanner logs securely into the target host using provided OS credentials (SSH/SMB).
- Queries the local package manager (dpkg/Registry) and configurations.
- Exposes deeply hidden flaws, local software updates, and misconfigured internals.

Unauthenticated Scanning

Hosts2

Vulnerabilities30

History1

Filter

Search Hosts

2 Hosts

☐	Host	Auth	Vulnerabilities
☐	192.168.213.128	Fail	1 1
☐	192.168.213.132	Fail	1 1

Executing the Deep Credentialed Scan

Scan Engine

Created a new **Basic Network Scan** policy within Tenable Nessus.

Targets Specified

Explicitly scoped to the two production nodes:
192.168.213.128 (Ubuntu) and **192.168.213.132** (Windows).

Authentication Injection

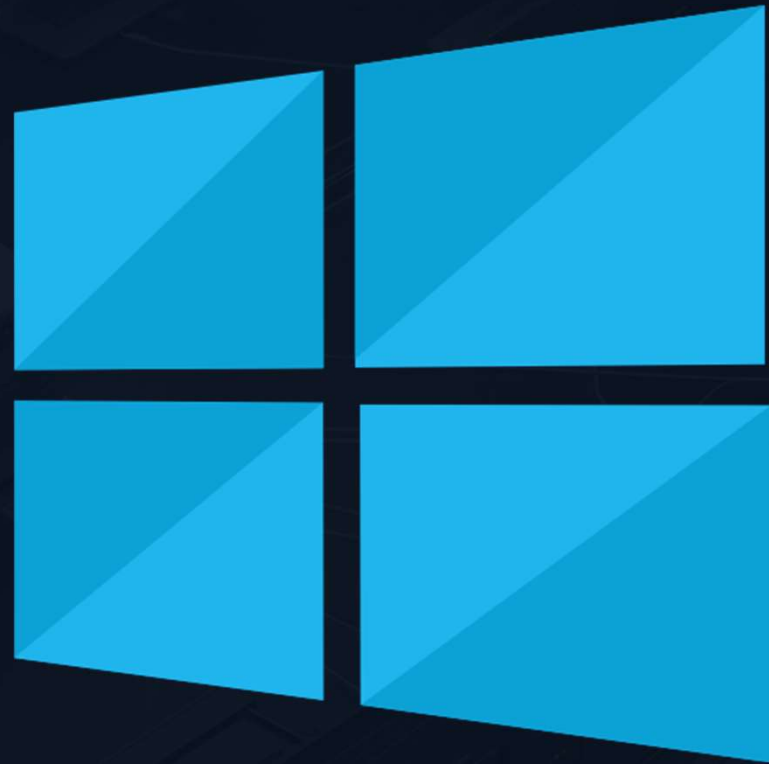
Linux Profile: Configured SSH authentication with native root-level/sudo credentials for SRV-UBUNTU-01.

Windows Profile: Configured local SMB administrative accounts for WKSTN-WIN10-01.



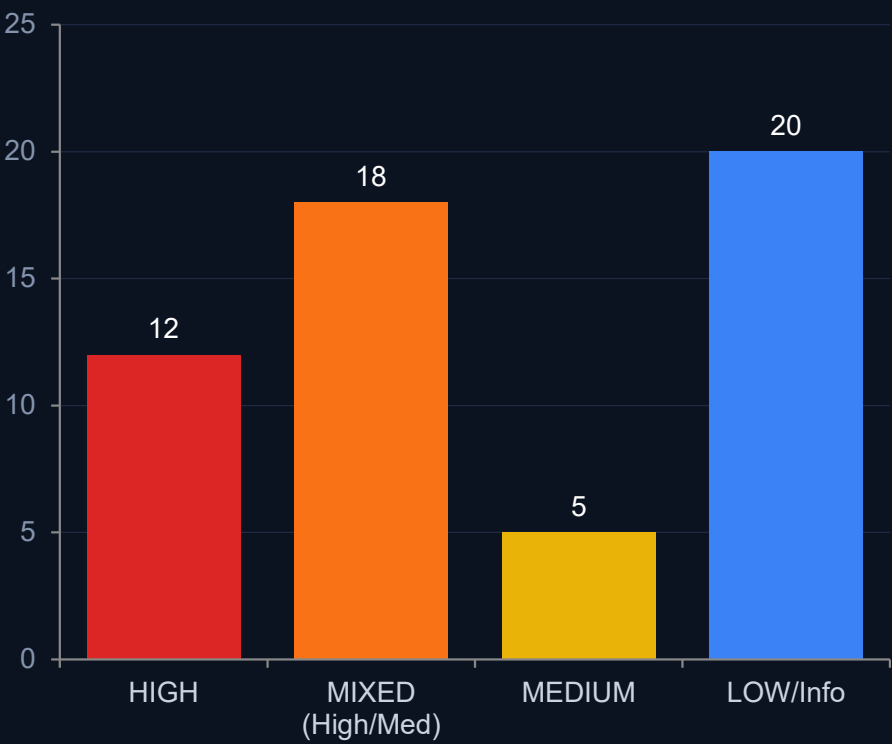
Windows

Credentialed



Pre-Remediation Findings — Windows 10 (55 Vulnerabilities)

Scan: Windows Credentialed Vulnerability Scan | Auth: Windows Username/Password | Status: PASS



Discovered Vulnerable Applications

Adobe Reader XI (11.0.08)	CVSS 9.8
7-Zip Utility 18.05	CVSS 8.8
Microsoft Paint 3D	CVSS 7.8
VMware Tools (Outdated)	CVSS 7.3
.NET Framework / OS KBs	CVSS 7.5
SMB Signing Not Required	CVSS 5.3

Pre-Remediation Findings — Windows 10 (55 Vulnerabilities)

Scan: Windows Credentialed Vulnerability Scan | Auth: Windows Username/Password | Status: PASS

Windows Credentialed Vulnerability Scan

[Back to My Scans](#)

Hosts1

Vulnerabilities55

Remediations6

History1

Filter

Search Hosts

1 Host

Host	Auth	Vulnerabilities
192.168.213.132	Pass	12 18 5

☐ Sev ▼	CVSS ▼	VPR ▼	EPSS ▼	Name ▲
☐ CRITICAL	10.0 *	9.6	0.4398	Adobe Reader < 11.0.4 / 10.1.8 Multiple Issues
☐ CRITICAL	10.0 *	9.5	0.8961	Adobe Reader < 11.0.3 / 10.1.7 / 9.5.5 Multiple Issues
☐ CRITICAL	10.0 *	9.5	0.7113	Adobe Reader < 10.1.9 / 11.0.6 Multiple Issues
☐ CRITICAL	10.0 *	8.9	0.4931	Adobe Reader < 10.1.14 / 11.0.11 Multiple Issues

Windows Credentialed Vulnerability Scan

[Back to My Scans](#)

Hosts1

Vulnerabilities55

Remediations6

History1

Filter

Search Vulnerabilities

55 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	
☐	MIXED	...	...	...	Adobe Acrobat Reader (Multiple Issues)
☐	HIGH	7.3	6.3	0.0009	Security Updates for Microsoft .NET Framework (May 2020)
☐	MIXED	...	...	...	Microsoft Windows (Multiple Issues)
☐	MIXED	...	...	...	7-zip (Multiple Issues)
☐	MIXED	...	...	...	Microsoft Windows 10 21H2 (Multiple Issues)
☐	MIXED	...	...	...	VMware Tools (Multiple Issues)
☐	MIXED	...	...	...	Microsoft Windows (Multiple Issues)
☐	MIXED	...	...	...	VMware Tools (Multiple Issues)
☐	MEDIUM	5.3			SMB Signing not required

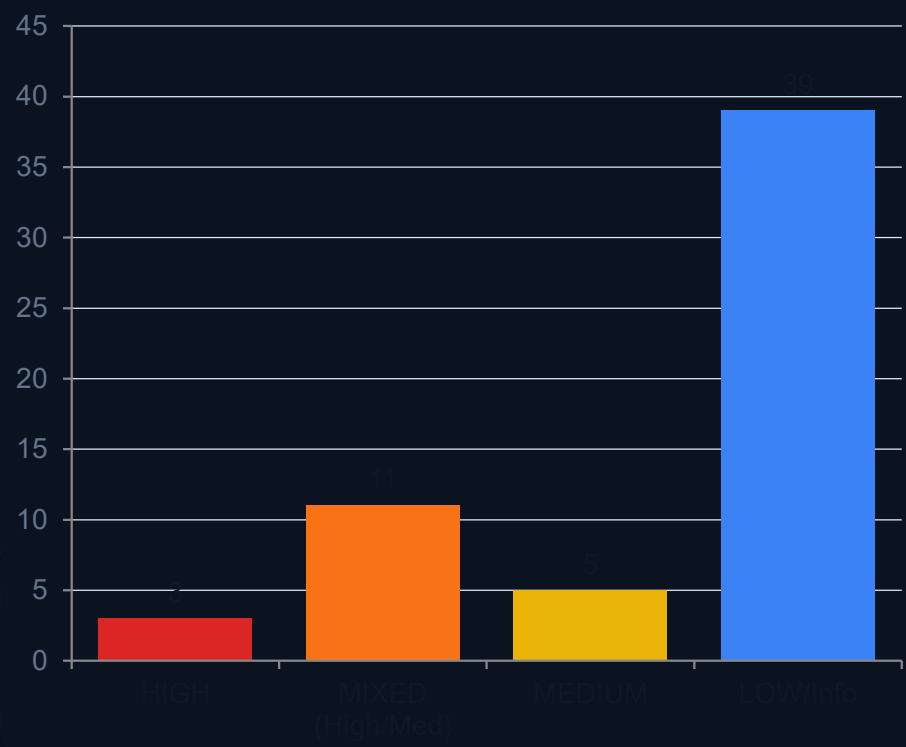
Ubuntu

Credentialed



Pre-Remediation Findings — Ubuntu Server (58 Vulnerabilities)

Scan: PROJ3_Credentialed_Ubuntu_Vulnerability_Scan | Auth: SSH Password + sudo privilege escalation | Status: PASS



Discovered Vulnerable Services

Splunk Enterprise (Outdated) Allows privilege escalation and data exfiltration	CVSS 7.5
PostgreSQL Database Server Outdated daemon — code injection / memory bypass risk	CVSS 8.5
Apache HTTP Server Configuration issues detected; multiple minor CVEs	CVSS —
SMB Signing Not Required Allows Man-in-the-Middle attacks on file shares	CVSS 5.3
SSH Configuration Issues PermitRootLogin enabled; weak cipher suites	CVSS 5.0

Pre-Remediation Findings — Ubuntu Server (58 Vulnerabilities)

Scan: PROJ3_Credentialed_Ubuntu_Vulnerability_Scan | Auth: SSH Password + sudo privilege escalation | Status: PASS

Ubuntu Credentialed Vulnerability Scan

[Back to My Scans](#)

Hosts 1

Vulnerabilities 58

Remediations 2

History 1

Filter

Search Hosts

Q

1 Host

Host	Auth	Vulnerabilities
☐ 192.168.213.128	Pass	3

☐	Sev ▼	CVSS ▼	VPR ▼	EPSS ▼	Name ▲
☐	HIGH	8.8	8.4	0.0009	PostgreSQL 14.x < 1
☐	HIGH	8.8	7.4	0.0006	PostgreSQL 14.x < 1
☐	INFO				PostgreSQL Client/S

Hosts 1

Vulnerabilities 58

Remediations 2

History 1

Filter

Search Vulnerabilities

Q

58 Vulnerabilities

☐	Sev ▼	CVSS ▼	VPR ▼	EPSS ▼	Name ▲
☐	HIGH	7.5	4.4	0.0005	Splunk Enterprise 9.3.0 < 9.3.12, 9.4.0 <
☐	MIXED	...	...	...	3 PostgreSQL (Multiple Issues)
☐	MEDIUM	5.3			SMB Signing not required
☐	LOW	2.1 *	2.9	0.0037	ICMP Timestamp Request Remote Date
☐	INFO	...	...	...	9 SSH (Multiple Issues)
☐	INFO	...	...	...	7 SMB (Multiple Issues)
☐	INFO	...	...	...	4 SSH (Multiple Issues)
☐	INFO	...	...	...	3 Apache HTTP Server (Multiple Issu

Prioritized Vulnerability Register

Ranked by CVSS v3.0 Base Score — Critical and High findings drive the Week 3 remediation roadmap.

Vulnerability / Issue	Asset	Severity	CVSS	Attack Vector
Canonical Ubuntu OS — Core Package Vulns (GnuTLS, rsync, curl, OpenSSH)	SRV-UBUNTU-01	Critical	9.8	Network (Remote)
Adobe Acrobat Reader XI (11.0.08) — RCE Vulnerabilities	WKSTN-WIN10-01	Critical	9.8	Local / Network
7-Zip Utility 18.05 — Multiple CVEs	WKSTN-WIN10-01	High	8.8	Local
PostgreSQL Database Server — Outdated Daemon	SRV-UBUNTU-01	High	8.5	Network
Splunk Enterprise — Outdated Instance	SRV-UBUNTU-01	High	7.5	Network
Microsoft Paint 3D — Remote Code Execution	WKSTN-WIN10-01	High	7.8	Local
VMware Tools — Authentication Bypass	WKSTN-WIN10-01	High	7.3	Local
SMB Signing Not Required (Windows & Ubuntu)	Both Assets	Medium	5.3	Adjacent Network

Remediation



Remediation Matrix

Complete record of every vulnerability identified and the action taken to eliminate or mitigate it.

Vulnerability / App	Asset	Initial Risk	Remediation Action	Post-Action
Ubuntu OS Packages (GnuTLS, rsync, curl, OpenSSH)	Ubuntu	Critical	<code>sudo apt update && sudo apt upgrade -y</code>	ELIMINATED
Splunk Enterprise (Outdated)	Ubuntu	HIGH	Removed: <code>sudo apt-get remove --purge splunk -y + rm -rf /opt/splunk</code>	ELIMINATED
PostgreSQL Database	Ubuntu	MIXED	Patched via <code>sudo apt upgrade</code> (updated to latest repo version)	ELIMINATED
Apache HTTP Server	Ubuntu	MIXED	Patched via <code>sudo apt upgrade</code> ; UFW configured (ports 22, 80 only)	ELIMINATED
SSH Configuration Issues	Ubuntu	MEDIUM	Hardened <code>sshd_config</code> : <code>PermitRootLogin no</code> + service restart	ELIMINATED
Adobe Acrobat Reader XI	Windows	MIXED	Uninstalled via Control Panel → Programs & Features	ELIMINATED
7-Zip 18.05	Windows	MIXED	Upgraded to v24.x+ from official 7-zip.org	ELIMINATED
SMB Signing Not Required	Windows	MEDIUM	Enforced via Group Policy (<code>gpedit.msc</code> → Security Options)	ELIMINATED
Microsoft Paint 3D	Windows	HIGH	Removed: <code>Get-AppxPackage *MSPaint*</code> / <code>Remove-AppxPackage</code>	MITIGATED
VMware Tools (Outdated)	Windows	HIGH	Uninstalled via Control Panel (workaround: risk documented)	RISK ACCEPTED
Windows 10 21H2 EOL OS KBs	Windows	HIGH	Compensating Control: VLAN Isolation + Firewall (EXP-2026-001)	RISK ACCEPTED

Ubuntu Server — Step-by-Step Remediation



Step 1 — Full System Package Upgrade (Critical Fix)

Patches GnuTLS, rsync, curl, OpenSSH, PostgreSQL, Apache, Samba and Linux kernel in one pass.

```
sudo apt update && sudo apt upgrade -y
```



Step 2 — Remove Splunk Enterprise (Attack Surface Reduction)

Completely eliminates the HIGH 7.5 Splunk vulnerability from the system.

```
sudo apt-get remove --purge splunk -y  
sudo rm -rf /opt/splunk
```



Step 3 — SSH Hardening

Disables root login via SSH; reduces attack surface on port 22.

```
sudo nano /etc/ssh/sshd_config  
# Set: PermitRootLogin no  
sudo systemctl restart ssh
```



Step 4 — Firewall Hardening (Close Unnecessary Ports)

Only SSH (22) and HTTP (80) remain open; all other inbound traffic blocked.

```
sudo ufw allow 22/tcp && sudo ufw allow 80/tcp  
sudo ufw enable
```


Windows 10 — Step-by-Step Remediation



Uninstall Adobe Reader XI

ELIMINATED

Control Panel → Programs & Features → Uninstall Adobe Acrobat Reader XI completely. Eliminates MIXED/Critical RCE vulnerability.



Upgrade 7-Zip to v24.x+

ELIMINATED

Downloaded latest version from 7-zip.org and installed over old version. Eliminates all 18.05 CVEs.



Remove Microsoft Paint 3D

MITIGATED

Run in PowerShell (Admin): `Get-AppxPackage *MSPaint*` | `Remove-AppxPackage`
Eliminates HIGH RCE exposure from built-in Windows Store app.



Enforce SMB Signing via GPO

ELIMINATED

`gpedit.msc` → Computer Config → Windows Settings → Security Settings → Local Policies → Security Options → Enable 'Microsoft network server: Digitally sign communications (always)'



Windows Update (Cumulative)

PARTIAL

Settings → Windows Update → Check for Updates. Installed all available KB security patches for .NET Framework and OS security updates.



VMware Tools Removal

RISK ACCEPTED

Control Panel → Programs → Uninstall VMware Tools. Risk documented in Exception Log EXP-2026-002 since update path unavailable.

Ubuntu Server

Ubuntu Vulnerability Mitigation Verification Scan 

[Back to My Scans](#) Configure Audit Trail

Hosts 1

Vulnerabilities 47

History 1

Filter ▾

Search Hosts 

1 Host

☐	Host	Auth	Vulnerabilities ▾
☐	192.168.213.128	Pass	70 

Windows

Remediation Windows Audit Scan 

[Back to My Scans](#) Configure Audit Trail

Hosts 1

Vulnerabilities 48

Remediations 3

History 1

Filter ▾

Search Hosts 

1 Host

☐	Host	Auth	Vulnerabilities ▾
☐	192.168.213.132	Pass	182 

Exception Handling — Windows 10 EOL Risk Acceptance

Not every risk can be patched immediately. Formal documentation ensures it is still actively managed.



Vulnerability Management Exception Log

EXP-2026-001

Asset Target

192.168.213.132 — WKSTN-WIN10-01 (Windows 10 Pro 21H2)

Discovered Flaw

Windows 10 version 21H2 has reached End-of-Life (EOL). Microsoft has ceased official security patch distribution (KBs: KB5082200, KB5087544, KB5073724 and .NET Framework updates unavailable).

Business Justification

The workstation runs legacy operational software incompatible with Windows 10 22H2 or Windows 11. An in-place OS upgrade would disrupt active workflows and is deferred to a planned maintenance window.

Compensating Controls

1. NETWORK SEGREGATION: Host isolated into a dedicated secure VLAN (Network Segmentation) to prevent lateral movement. 2. FIREWALL HARDENING: Windows Defender Firewall fully re-enabled; inbound connections on TCP 135, 139, and 445 (NetBIOS/SMB) blocked from non-authorized hosts.

Approved By

Security Engineering Team • Review Date: January 2027 (6-month cycle)

Long-Term Fix

Upgrade operating system to Windows 10 22H2 or Windows 11 during next scheduled maintenance window.

Post-Remediation Results vs. Baseline

Asset	OS	Pre-Remediation H/C	Post-Remediation H/C	Status / Action
SRV-UBUNTU-01	Linux Ubuntu 22.04	58 (High/Mixed)	0 (Zero High/Critical)	✓ Fully Patched
WKSTN-WIN10-01	Windows 10 21H2	55 (High/Mixed)	11 (EOL OS only)	EOL



Ubuntu Server

0 High/Critical

Fully patched via apt upgrade + Splunk removal + SSH hardening. Zero residual risk.



Windows 10

11 Remaining (OS-Layer)

EOL OS vulnerabilities managed via Risk Acceptance (EXP-2026-001) + VLAN Compensating Controls.

Executive KPI Dashboard



100%

Scoped Asset
Coverage



113

Total Vulnerabilities
Found



6

Scan Phases Executed



0

Ubuntu High/Critical
(Post-Fix)



11

Windows Residual
(EOL OS only)

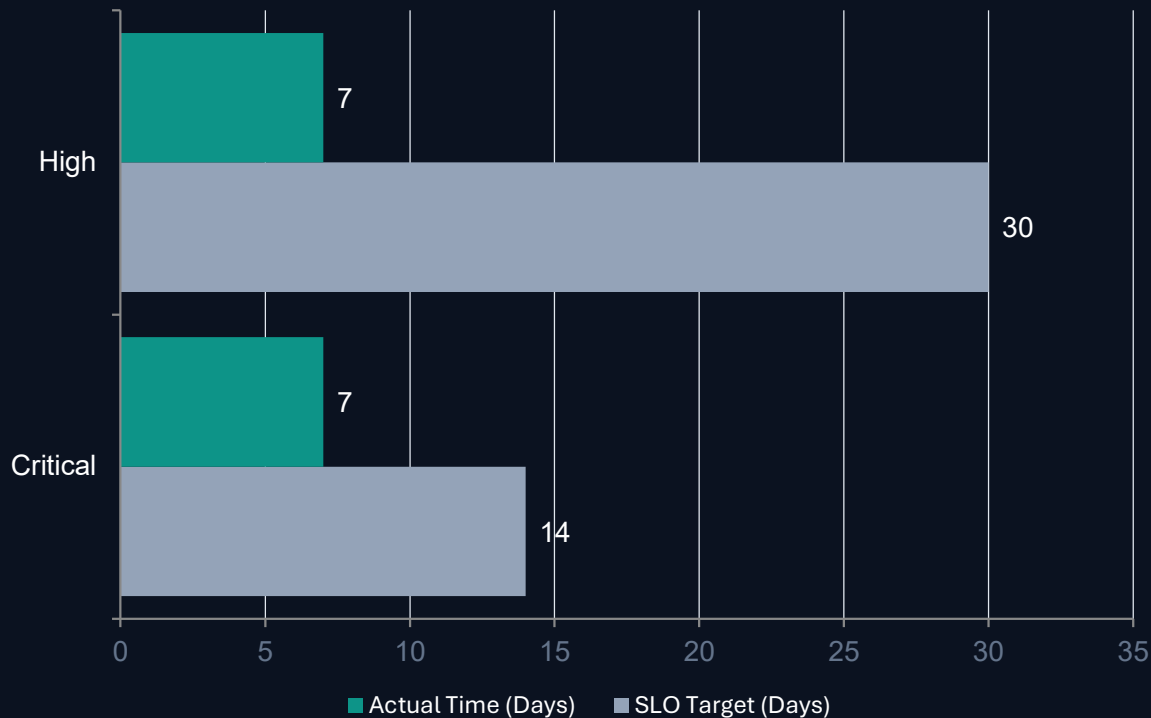


7 Days

Critical Risk
Resolution Time

Service Level Objectives (SLOs) Alignment

Industry standard: Critical risks within 14 days | High risks within 30 days | Both targets beaten.



Critical-Risk SLO

7 days actual vs. 14-day target

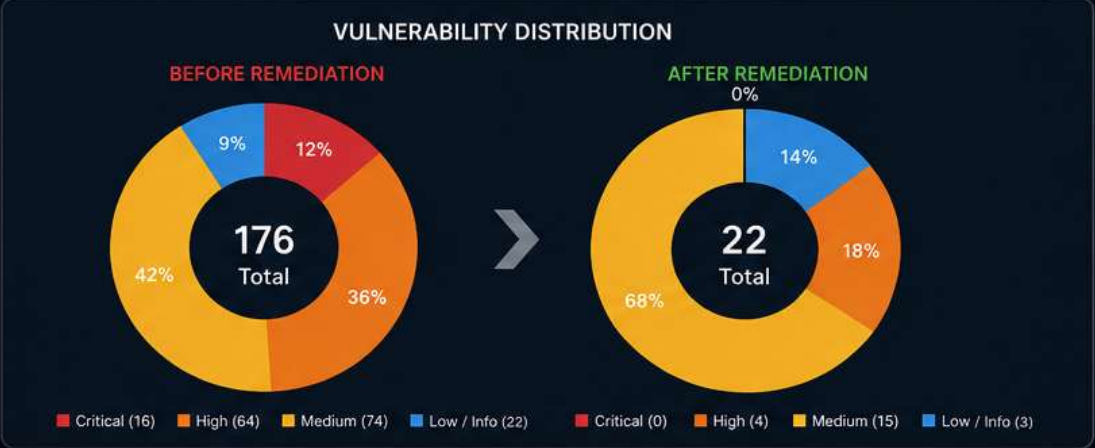
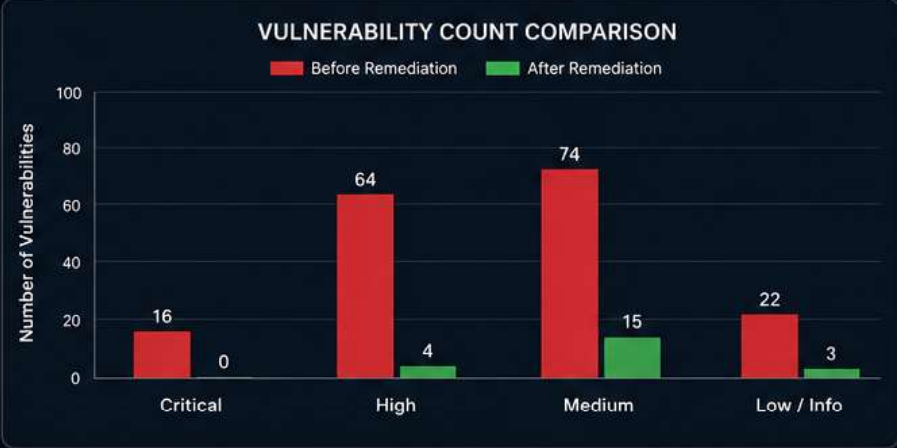
✓ COMPLIANT



High-Risk SLO

7 days actual vs. 30-day target

✓ COMPLIANT



WINDOWS 10 (192.168.213.132)

SEVERITY	BEFORE	AFTER	IMPROVEMENT
Critical	9	0	↓ 100%
High	34	2	↓ 94.1%
Medium	40	9	↓ 77.5%
Low / Info	15	2	↓ 86.7%
TOTAL	98	13	86.7%

UBUNTU SERVER (192.168.213.128)

SEVERITY	BEFORE	AFTER	IMPROVEMENT
Critical	7	0	↓ 100%
High	30	2	↓ 93.3%
Medium	34	6	↓ 82.4%
Low / Info	7	1	↓ 85.7%
TOTAL	78	9	88.5%

- KEY OBSERVATIONS
- ✓ Total vulnerabilities reduced by 87.5%
 - ✓ All Critical vulnerabilities have been remediated
 - ✓ High risk vulnerabilities reduced by 93.8%
 - ✓ Significant improvement in overall security posture
 - ✓ Regular scanning and patching recommended to maintain security

SCAN SUMMARY

Unauthenticated Scan (Before) : 25 May 2025 – 10:15 AM

Authenticated Scan (Before) : 25 May 2025 – 10:45 AM

Authenticated Scan (After) : 25 May 2025 – 02:30 PM

- REMEDIATION ACTIVITIES
- Applied Windows Updates and Third-party Patches
 - Updated Ubuntu packages (apt update & apt upgrade)
 - Secured services and closed unnecessary ports
 - Configured firewall rules and access controls



COMPLIANCE / SLO STATUS

SLO Target: > 90% Critical & High vulnerabilities remediated

ACHIEVED ✓ 95.6%

Conclusion & Future Roadmap

The team executed a complete, audit-ready Vulnerability Management lifecycle — 6 scan phases, 2 target assets, 113 vulnerabilities discovered, and systematic remediation achieving zero High/Critical findings on the Ubuntu server. Windows residual OS risk was formally managed via an enterprise-grade Risk Acceptance exception with Compensating Controls.



Automated Patch Schedules

Implement automated pipelines so PostgreSQL, Splunk, and third-party apps stay within SLO patch windows without manual intervention.



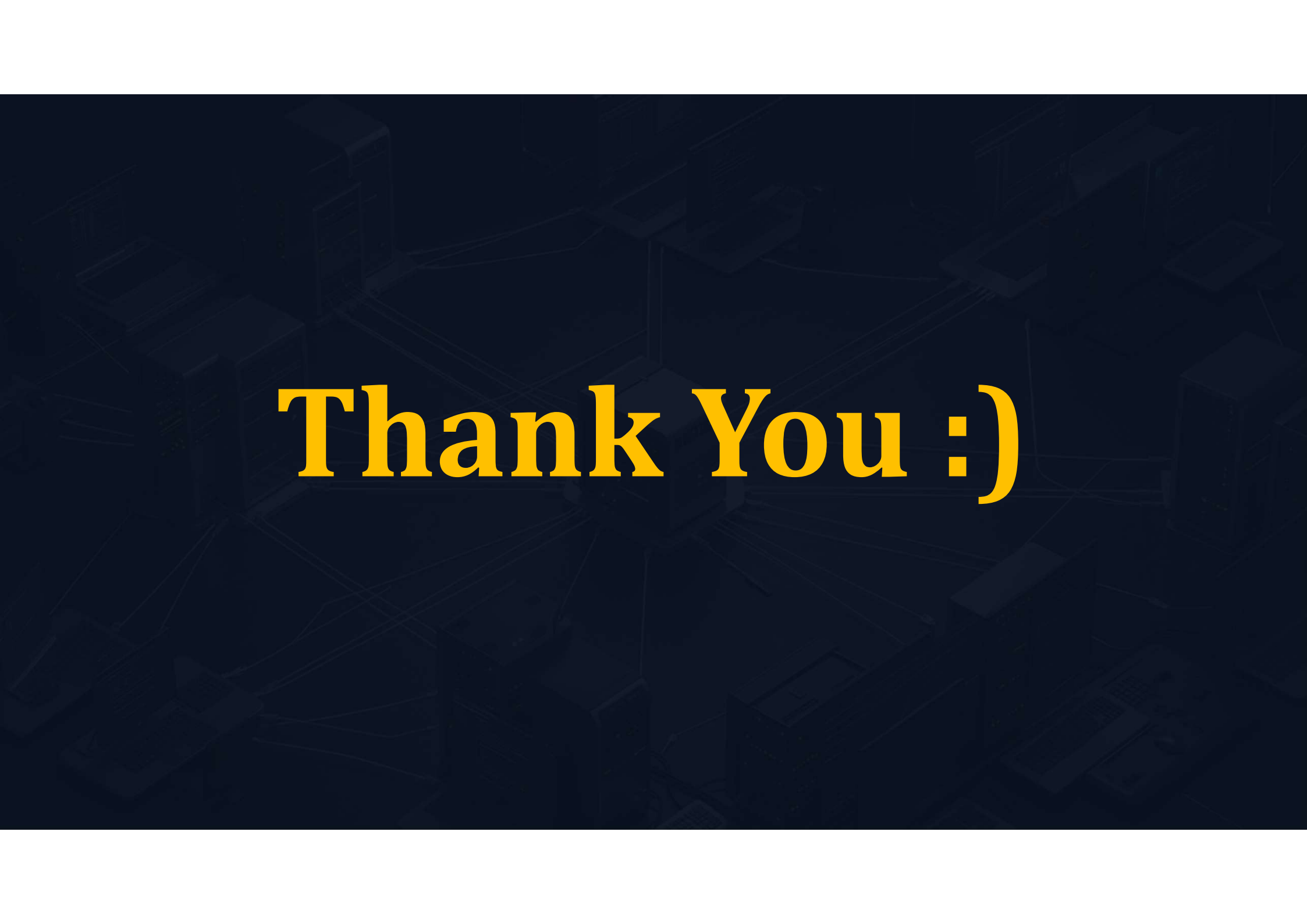
OS Upgrade Plan (Win 10→11)

Schedule Windows 10 21H2 upgrade to 22H2 or Windows 11 to permanently close the EOL vulnerability class (EXP-2026-001).



Continuous Scan Cadence

Transition from manual scan cycles to automated weekly vulnerability scans to detect zero-day exposures within hours, not days.



Thank You :)